Operationalising the MAS Guidelines on AI Risk Management for LLM and Agentic Systems: A Machine-Checkable Control Catalogue and Empirical Study

Thanatchon Chongmankhong

airmkit v0.1.0 · results run 2026-10-13 (98da8d7)

Abstract Supervisory guidance on artificial intelligence is written in principles and audited in artefacts. The Monetary Authority of Singapore's *Guidelines on Artificial Intelligence Risk Management* (7 October 2026) exemplify the genre: they require a use-case-level assessment of Impact, Complexity and Reliance, lifecycle controls from data to retirement, and tested guardrails for generative and agentic systems, while prescribing no formula, metric or threshold. We ask how much of such a text can be made machine-checkable, and we measure the attempt rather than assert it. We transcribe all 65 paragraphs (51 expectations, 29 normative footnotes) into a machine-readable catalogue, implement 65 controls that each cite the paragraph they serve and are classified by automatability, author a 224-row crosswalk to six other frameworks, and run five pre-registered experiments on a fictional bank's portfolio of 8 synthetic AI use cases. Of 17 hypotheses fixed before the experiments ran, 10 held and 7 were refuted. 45.1% of expectations admit a fully automated check, but the share is 84.6% in the inventory and materiality section and 0.0% in the governance section, and at control level the semi-automatable class dominates (36.9%). Moving a use case up a six-rung autonomy ladder enlarges its control set monotonically yet rarely changes its tier. On a local qwen3.5:0.8b model, the guardrail patterns that cut attack success from 75.0% to 6.2% also refused 50.0% of benign in-scope requests, so no pattern met both pre-registered thresholds. No single framework fully covers more than 49.0% of expectations; the union of ISO/IEC 42001, the NIST AI RMF and the EU AI Act leaves 35.3% without a full mapping, and the residue is governance machinery and Singapore-specific proportionality rather than the agent-specific clauses we predicted. Evidence volume is flat across materiality tiers (91.4 items at Critical against 92.0 at Medium): proportionality scales the rigour of review, not the number of artefacts, and 93.1% of estimated effort lies in work that automation cannot finish. Two instrument defects found during measurement are disclosed, including a truncation bug that produced a perfect 0% attack success rate. The catalogue, controls, crosswalk and experiments are released as an Apache-2.0 package, `airmkit`, so that every classification can be disputed row by row.

Keywords AI governance · model risk management · MAS · LLM evaluation · agentic AI · guardrails · regulatory crosswalk · pre-registration

> **Disclaimer.** airmkit is an independent open-source project, not affiliated with or endorsed by the Monetary Authority of Singapore. It is not legal, regulatory or compliance advice and is not a substitute for reading the Guidelines on Artificial Intelligence Risk Management (7 October 2026). Interpretations and all thresholds are the authors'.

1 Introduction

Financial supervisors have moved from principles to expectations for artificial intelligence. After the FEAT principles of 2018 [1], the Veritas assessment methodologies [2], [3] and a 2024 thematic review of AI model risk management [4], the Monetary Authority of Singapore (MAS) issued its *Guidelines on Artificial Intelligence Risk Management* on 7 October 2026 [5], closing consultation P017-2025 [6] with a published Response to Feedback [7]. The Guidelines bind on a phased timetable: the governance, identification, inventory and risk-materiality expectations of Sections 3 and 4 by 7 October 2027, and the lifecycle and capability expectations of Sections 5 and 6 by 7 October 2028 (§1.8). Internationally they sit alongside ISO/IEC 42001 [8], the NIST AI Risk Management Framework and its Generative AI Profile [9], [10], the EU AI Act [11] and the model-risk tradition of SR 11-7 and SS1/23 [12], [13], a landscape that the Bank for International Settlements and the Financial Stability Board have both described as converging in intent but diverging in form [14], [15].

Like most supervisory guidance, the text is qualitative by design. It requires each AI use case to be assessed on Impact, Complexity and Reliance (§4.12) but prescribes no formula; it requires the guardrails of generative and agentic systems to be tested for *effectiveness* (§5.15, fn46) but sets no threshold. The regulator is explicit that this is a choice: a prescribed materiality methodology "would not suit every institution" (Response §7.19) and indicative performance thresholds would depend on the materiality of the use case and the institution's risk appetite (Response §10.29). Every institution must therefore close the gap between principle and artefact on its own, and must close

it twice over for agentic systems, where the objects to be governed — tool permissions, autonomy levels, guardrail test results, action traces — have no settled inventory schema [16], [17].

This paper treats the gap as an empirical question. The practical issue is not whether such guidance *should* be operationalised but how far it *can* be, what is lost in the attempt, and what remains for human judgement when the automatable part is done. We therefore built an operationalisation and measured it under pre-registered hypotheses, reporting the refutations with the same prominence as the confirmations.

Our contributions are:

1. **A machine-readable clause catalogue** of the Guidelines: 65 paragraphs, of which 51 state an expectation, with 51 footnotes of which 29 carry requirements (among them the agent inventory attributes of fn25 and the shadow-AI controls of fn22), each with its effective date, applicability and tags.
2. **A control catalogue** of 65 controls in 20 families, each citing the paragraphs it serves and classified by an explicit automatability scheme, with 58 evaluated per use case and 7 per institution. One expectation (§2.2) is deliberately left without a control, for a reason given in §6.
3. **A transparent risk-materiality rubric** over the three dimensions of §4.12, built from 23 signals that each cite the paragraph they derive from, together with a documented interpretation protocol for eleven ambiguous readings of the text.
4. **A crosswalk** of 224 mapping rows from the 51 expectations to ISO/IEC 42001, the NIST AI RMF and its Generative AI Profile, the EU AI Act, the FEAT principles and the 2024 MAS Information Paper, each row carrying a justification and a confidence grade.
5. **Five pre-registered experiments** with thresholds and refutation criteria fixed before implementation, run on a synthetic portfolio, with every number in this paper injected from a single results file and every verdict reported.
6. **An Apache-2.0 toolkit**, `airmkit`, that produces the inventory register, materiality report, control applicability statement, gap analysis by effective date and board summary as reproducible artefacts, and exports every format as JSON Schema for adoption without the library.

The findings of greatest use are negative. Automation stops well short of the Guidelines' substance and stops earliest in the governance clauses that bind first. Guardrail patterns that look effective against adversarial suites refuse half of ordinary traffic. The work an internationally certified institution still faces is governance work, not agent work. And the proportionality the Guidelines ask for shows up as deeper review of the same artefacts, not as more artefacts. Each of these is reported against the threshold it failed, and two defects in our own measurement instruments are disclosed because, uncorrected, each would have produced a flattering result.

2 Background

2.1 Structure of the Guidelines

The Guidelines apply to all financial institutions in Singapore and, for locally incorporated institutions under consolidated supervision or owning critical information infrastructure, on a group basis (§1.2). Section 1 defines AI, models, systems and use cases (§1.3–§1.4), restates the risk landscape including the amplified risks of generative AI and the "unauthorised or erroneous actions" of agents (§1.10–§1.11), and sets the transition (§1.8). Section 2 provides the applicability test: an institution whose AI use could have a material adverse impact applies the full regime, and one below that threshold applies a basic governance regime of accountable senior management, permitted and prohibited uses, an approved-tool list, staff education and periodic review (§2.2–§2.5).

Section 3 places governance with the board and senior management and requires control functions for identification, inventory and materiality assessment (§3.3–§3.6). Section 4 requires consistent identification of AI use including AI embedded in services from material third-party providers (§4.2, fn21), management of the *residual* risk from AI that is not identified (§4.4, fn22), an inventory with specified attributes and an agent-specific extension (§4.5–§4.9, fn24–fn25), and a use-case-level assessment of risk materiality over Impact, Complexity and Reliance (§4.10–§4.13). Section 5 covers the lifecycle: roles, data, transparency and explainability, fairness, human oversight, third-party AI, selection, evaluation and testing, security, pre-deployment review and independent validation, monitoring, change management and retirement (§5.1–§5.26). Section 6 addresses competence, conduct and capability, extended in the final text to personnel *using* AI rather than only those building it (§6.1).

Three definitional features matter for what follows. First, materiality is anchored on the *use case*, not the model or system, and the definition of a use case in §1.4 is the context in which a model or system is applied, so the same model can carry different tiers in different uses. Second, footnotes carry requirements: fn25 lists the attributes an agent inventory entry may include, fn22 lists technical controls for unidentified AI, and fn46 lists failure modes

of generative AI that evaluation must cover. A catalogue that indexes only numbered paragraphs would miss a material part of the obligations. Third, the Guidelines are deliberately silent on method where method would be institution-specific, and the Response to Feedback records that silence as a decision rather than an omission (§7.19, §10.28–§10.29, §10.66). Everything quantitative in this paper is therefore the authors' proposal and is labelled as such.

2.2 From consultation to final text

We diffed the November 2025 consultation draft against the final Guidelines and recorded 36 substantive changes with a full paragraph concordance (`docs/WHAT_CHANGED.md`). The direction of change is *proportionate* rather than *lenient*. On the easing side, the single twelve-month transition became phased (§1.8); the "integrated into business processes" applicability test, with its annex flowchart and example list, was replaced by a material-adverse-impact test (§2.2–§2.4); a dedicated cross-functional AI committee is no longer required (§3.3); the inventory must be accurate "to the extent possible or practicable" at an institution-chosen frequency (§4.5); human review of *all* AI outputs became "effective human oversight" (§2.5); and data representativeness moved from "the full range" to "a range" of real-world conditions (§5.4(b)).

On the tightening side, residual risk from unidentified AI must now be kept within appetite with named mitigations (§4.4, fn22); agent attributes — identifiers, tools and systems accessible, components, guardrails — appear as an example attribute set (fn25); evaluation of generative AI and agents must cover key failure modes *and the effectiveness of the associated guardrails* (§5.15, fn46); third-party AI carries the institution's primary accountability with limit, suspend or replace where residual risk exceeds appetite, and with certifications or independent external assessments preferred over vendor self-attestations (§5.10–§5.11, Response §9.9); enhanced logging of prompts, responses, model versions and reasoning became a monitoring consideration for generative and agentic systems (§5.23(d)); and the board must now approve and regularly review the strategic direction for AI use (§3.4).

Two of these changes shape the experiments directly. The guardrail-effectiveness duty of §5.15 is what RQ3 measures, and the fn25 attribute set is what makes an agent inventory schema necessary at all.

2.3 Why qualitative guidance resists automation

Three structural properties of supervisory text explain why operationalisation is a measurement problem rather than an engineering one. First, obligations are stated at the level of *outcomes* ("effective human oversight") rather than *artefacts* (a documented escalation rule), so a check can confirm that an artefact exists and is current but not that it achieves the outcome. Second, obligations are *proportionate*: the same paragraph binds differently at different materiality tiers, so applicability is a function of a judgement the institution must make first. Third, obligations are *organisational*: a board's review of strategic direction leaves no artefact a program can inspect without reducing it to a signature. The automatability classification of §4.3 is designed to make these three properties visible in the data rather than to argue them away, and the central empirical claim of this paper is that the three properties are unevenly distributed across the Guidelines' sections.

3 Related work

Supervisory and standards frameworks. ISO/IEC 42001 specifies an AI management system and is auditable for certification [8], with ISO/IEC 23894 providing risk-management guidance and ISO/IEC 22989 the vocabulary [18], [19]. The NIST AI RMF organises risk functions into Govern, Map, Measure and Manage [9], and its Generative AI Profile enumerates twelve generative-AI risks with suggested actions [10]. The EU AI Act imposes product obligations on high-risk systems and on general-purpose models [11]. In financial services, SR 11-7 and SS1/23 define model risk management as a lifecycle with independent validation [12], [13], the HKMA has issued generative-AI consumer-protection expectations [20], and MAS's own FEAT principles and Veritas methodologies supply the fairness and transparency vocabulary the Guidelines inherit [1], [2], [21], [22]. Surveys by the BIS Financial Stability Institute and the FSB describe the regulatory landscape and its gaps [14], [15]. §7.4 measures how much of the Guidelines these frameworks already cover; the contribution here is not another framework but a mapping with the denominator fixed on the regulator's text.

Agent governance and visibility. The agent-specific clauses (§1.11, fn25, §5.9, §5.23(a)) presuppose that an institution can enumerate an agent's tools, permissions and actions. Chan et al. argue that increasingly agentic systems create harms that existing governance does not anticipate [23] and propose agent identifiers, real-time monitoring and activity logs as governance primitives [16]; Shavit et al. catalogue practices for governing agentic systems [17]; Kapoor et al. show that agent benchmarks routinely conflate capability with cost and reproducibility [24]; and ToolEmu demonstrates that risks from tool-using agents can be surfaced in an emulated sandbox before

deployment [25]. None of these supplies an inventory schema a supervisor could require, which is the gap fn25 opens and `airm.inventory` proposes to fill.

Guardrail and robustness evaluation. The adversarial literature is mature. Prompt injection was characterised by Perez and Ribeiro [26] and its *indirect* form, in which instructions arrive through retrieved content, by Greshake et al. [27]; AgentDojo and InjecAgent benchmark indirect injection against tool-using agents [28], [29]. Jailbreaks have been explained as competing objectives and mismatched generalisation [30], automated by gradient search [31] and by black-box iteration [32], and standardised in HarmBench [33]. Defences include classifier-based input–output safeguards [34] and programmable rails [35]; garak packages probes for operational use [36]; and the OWASP Top 10 for LLM applications and MITRE ATLAS organise the threat space for practitioners [37], [38]. What the literature does not supply is a mapping from a harness result to a supervisory control, or an accepted pass threshold per risk tier. We therefore build adapters rather than a harness, report our thresholds as proposals, and — following the observation that over-refusal is the hidden cost of safety training [30] — insist on a benign control set in every guardrail measurement.

Evaluation validity. HELM made the case that a benchmark number is a reading of an instrument under stated conditions [39]; LLM-as-a-judge studies quantify the agreement and biases of model-based graders [40]; RAGAS and FActScore provide reference-free and atomic measures of faithfulness [41], [42] against the backdrop of a broad hallucination literature [43]; and Inspect offers a reproducible harness used by a national safety institute [44]. We draw two lessons: record the instrument with the reading (model, digest, seed, sampling parameters), and calibrate detectors on a control condition rather than on the condition under test. §7.3 reports what happened when we did not initially do the second.

Documentation, audit and accountability. Model cards and datasheets established the documentation artefacts that lifecycle controls now assume [45], [46]; Raji et al. frame internal audit as an end-to-end process with traceable artefacts [47]; Weidinger et al. provide the risk taxonomy that fn46′s failure modes echo [48]; and fairness criteria such as equality of opportunity give the §5.7–§5.8 expectations an operational form where the use case affects individuals [49], [50]. The foundation-model literature frames the third-party concentration and homogenisation risks that §5.11(c) names [51].

A gap table in `docs/literature/REVIEW.md` lists the expectations with no established implementation pattern: shadow-AI coverage (§4.4), machine-readable vendor AI disclosure (§4.2), guardrail thresholds per tier (§5.15), traces checked against approved scope (§5.23(a)), a taxonomy of significant LLM changes (§5.25), tested kill switches (§5.3), automation bias (§5.9) and user competence (§6.1). With one exception discussed in §7.4, these are also the clauses that resist automation in §7.1.

4 Method

4.1 Source acquisition and clause extraction

All eleven primary documents — the Guidelines, the Response to Feedback, the consultation paper, the 2024 Information Paper, the FEAT principles and the Veritas documents — were acquired from mas.gov.sg and hashed; `docs/sources/MANIFEST.md` records a SHA-256 for each so that every citation in the toolkit can be verified offline. The Guidelines were transcribed by hand into `src/airm/catalog/mas_airm_2026.yaml` (design decision D-3: a hand-built catalogue reviewed against the PDF, rather than a parser that would drift on the next revision). Each paragraph carries its section, heading, a summary of at most forty words in our own words, a kind (expectation, definition, scope, context or guidance), who it applies to, its effective date under §1.8 as clarified by Response §13.5, and tags such as `genai`, `agent`, `third-party`, `inventory` and `human-oversight`. Footnotes are included where they carry a requirement. The catalogue is the sole source of truth for citation: a control that cites a paragraph not in the catalogue fails the test suite, which is the only mechanical defence we have against a control catalogue drifting into invention.

4.2 Interpretation protocol

Where a paragraph admits two readings, we implemented the stricter as the default, exposed the lenient one as configuration, and recorded both. Eleven such interpretations are documented in `docs/INTERPRETATIONS.md` (I-1 to I-11) and referenced from the controls that depend on them. Four are load-bearing for the results. I-3 keys the high-materiality triggers of §5.3, §5.19, §5.23(b) and §5.24 on the *inherent* rather than residual rating, following Response §7.21. I-4 fixes the combination rule for the three materiality dimensions, which the Guidelines leave open (§4.3 below). I-6 treats the fn25 agent attributes as expected for any use case tagged as an agent, although the footnote says “may include”, on the ground that a supervisor asking for the attribute set will not accept their

absence as a documented choice. I-8 requires a validator to be a different party from the owner, developer and deployer and not the vendor, following Response §10.55 and §10.58.

4.3 Control catalogue and automatability classification

Each of the 65 controls carries an identifier, the paragraphs it serves, applicability by inherent tier and by scope (use case or institution), the evidence items it requires, an optional automated check, and an automatability class with a written rationale. The class is the instrument on which RQ1 rests, and its definitions were fixed before classification began (D-6):

Table 1: Automatability classes, their operational definitions, and the distribution of expectation paragraphs and controls across them. A paragraph takes the best class among the controls that implement it; a control carries exactly one class.

Class	Meaning	Expectations	Controls
`auto`	a deterministic function of the inventory entry and its evidence decides the outcome	23 (45.1%)	20 (30.8%)
`semi`	presence and currency of the artefact is machine-checkable; adequacy needs human attestation	16 (31.4%)	24 (36.9%)
`doc`	organisational or judgemental; no artefact the toolkit inspects	12 (23.5%)	21 (32.3%)

A clause is `auto` only if a deterministic function of the inventory entry, its evidence files and ingested evaluation outputs decides pass or fail without human judgement about adequacy. It is `semi` if such a function can decide whether the required artefact exists and is current but not whether it is good enough. It is `doc` if compliance is an organisational or judgemental fact with no artefact the toolkit can inspect. The classification is relative to *this* implementation — a richer integration would move some `semi` controls to `auto` — and it was made by a single annotator, so no inter-rater agreement is available. Each row is published with its rationale so that it can be disputed individually without rejecting the scheme.

One consequence of the scheme governs how every count in this paper should be read: **a `semi` control never reports `PASS`**. When its automated check succeeds, the outcome is `NEEDS_ATTESTATION`, because the toolkit has established presence and currency but cannot establish adequacy. The attestation count in §6 is therefore a work queue, not a failure count, and `airm check` exits non-zero only on a genuine automated `FAIL`, since a pipeline that failed on attestations would teach engineers to suppress them.

4.4 Risk-materiality rubric

The rubric operationalises §4.12 from fields the inventory already carries under §4.7 and fn25. Twenty-three signals, each citing the paragraph it derives from, score Impact, Complexity and Reliance at four levels, and the three levels combine into an inherent tier of Low, Medium, High or Critical. The combination rule is *max with an impact gate* (D-5, I-4): the tier is the highest of the three levels, but Complexity and Reliance may raise it at most one level above Impact. The gate implements two points from the Response to Feedback — that Complexity is not a standalone driver (§7.9) and that the assessment should anchor on the consequences of failure (§7.5) — and the max rule is the strictest common reading of a text that does not prescribe one. The rubric is our proposal, not a MAS methodology. A residual tier is derived by crediting declared mitigations that the Guidelines name: human checkpoints at consequential steps (§5.9(c)), tested guardrails (§5.15), formal independent validation (§5.19), kill switches and contingency plans (§5.3, fn29), trace logging (§5.23(a), (d)) and independent vendor assessment (§5.11(a)). Every score carries its reasons, so an assessment can be argued with rather than only accepted, and a weighted-sum variant is run as a sensitivity check in RQ2.

Two structural properties of the defaults deserve statement before the results. First, the impact gate means an internal research assistant does not become Critical because it uses a large language model. Second, because generative AI sets Complexity to High and the gate permits one level above Impact, **no generative-AI use case can be rated Low** under the defaults. We report this as a finding about the rubric rather than tuning it away, and §7.5 shows how it weakens one hypothesis.

4.5 Synthetic portfolio

The worked example is Merlion Commercial Bank (fictional), with 8 AI use cases chosen to span the materiality range: a credit decision model, AML alert triage, a customer-service chatbot, an internal policy RAG assistant, an agentic KYC document processor, card fraud scoring, a vendor-provided transaction-monitoring service and a trading-signal research agent. 2 are agentic and 7 are rated High or Critical. The portfolio carries three third-party assessments, 266 synthetic evidence files and a 14-record hash-chained audit trail. No real institution's data appears anywhere in this work, and the portfolio was written by the same person who wrote the rubric, a dependency §8 returns to.

Table 2: The synthetic portfolio as the toolkit rates it: inherent and residual tiers under the default rubric, the number of applicable controls, and their split by automatability class.

Use case	Inherent	Residual	Applicable controls	auto	semi	doc
`credit-decision-model`	Critical	High	43	10	20	13
`aml-alert-triage`	Critical	High	43	10	20	13
`customer-service-chatbot`	High	Medium	55	15	24	16
`policy-rag-assistant`	Medium	Medium	49	15	19	15
`kyc-document-agent`	Critical	High	58	18	24	16
`card-fraud-scoring`	Critical	High	43	10	20	13
`vendor-txn-monitoring`	Critical	Critical	51	13	22	16
`research-signal-agent`	High	Medium	55	18	22	15

4.6 Pre-registration and analysis protocol

Five research questions were fixed in `docs/RESEARCH_QUESTIONS.md` before the experiments were implemented, each with a hypothesis, the experiment that would refute it, the metric and the decision threshold:

- **RQ1 Automatability.** What fraction of MAS-AIRM expectations can be automatically checked from artefacts, semi-automated with human attestation, or only documented? *Method:* Each of the 51 expectation paragraphs takes the best automatability class among the controls implementing it; paragraphs with no implementing control count as doc. Classes and their justifications are in src/airm/controls/controls.yaml.
- **RQ2 Autonomy and materiality.** Holding purpose and data fixed, how does autonomy change Impact/Complexity/Reliance and which Section 5 controls become binding? *Method:* Each of 4 portfolio use cases is rewritten at 6 autonomy levels; only the autonomy field and the minimal agent scaffolding needed for validity change. Applicable controls are those the catalogue selects for the variant.
- **RQ3 Guardrail effectiveness.** For common guardrail patterns, what is the measured failure rate under standard adversarial probe families, and does it meet a defensible threshold per materiality tier? *Method:* 20 probes across 5 families (4 attack families plus a benign control set) run under 5 guardrail patterns. Detection is by regular expression, never by a model, so the measurement does not depend on the thing being measured. Wilson 95% intervals throughout.
- **RQ4 Crosswalk coverage.** What share of MAS-AIRM expectations is covered, partially covered or uncovered by ISO/IEC 42001, NIST AI RMF and the EU AI Act, and what residual work does an already-certified institution face? *Method:* 224 hand-authored mapping rows over 51 expectation paragraphs. The denominator is the expectation count, not the mapped-row count, so an unmapped expectation counts against coverage rather than being excluded.
- **RQ5 Cost of compliance.** How many controls, evidence items and estimated person-hours does each materiality tier require, and where is the long tail? *Method:* Applicable controls and their evidence items are counted per use case from the control catalogue, then multiplied by a per-item effort estimate that varies with the control's automatability class and a tier multiplier. Institution-level controls are counted once.

Verdicts are mechanical against the recorded thresholds. Proportions are reported with Wilson 95% intervals, and a guardrail pattern "meets" a tier only if the *upper* bound of its interval lies below the tier's limit, so that a small sample cannot manufacture a pass. Monotonicity is tested with Kendall's τ. Where implementation forced a change to a pre-registered construct, the original hypothesis is reported as refuted on its original wording and any revised test is labelled as not pre-registered; §7.2 is the one such case. Where a measurement instrument was found to be defective, the defect, its direction of bias and the correction are recorded in the result file and reproduced here; §7.3 has two such cases. These rules were adopted so that the reader can distinguish what the pre-registration predicted from what the implementation taught us, which is the distinction a pre-registered study exists to preserve.

5 The toolkit

`airmkit` installs with `pip install airmkit` and imports as `airm`. Thirteen modules follow the structure of the Guidelines rather than the structure of a software product, so that a reader of the text can find the code that serves a paragraph and a reader of the code can find the paragraph that justifies it.

- `airm.catalog` holds the clause catalogue and a query API.
- `airm.inventory` provides Pydantic models for a use case per §4.7, an `AgentExtension` carrying the fn25 attributes (identifier, approved tools, systems accessible, permissions, components, guardrails, human checkpoints, step limits, whether the agent can initiate external actions, whether traces are logged), register validation, diff

and completeness scoring. Autonomy level and the presence of an agent extension are validated together: an agentic level without the extension is an error, and so is the reverse.

- `airm.scan` performs shadow-AI discovery over a repository (§4.2 fn21, §4.4 fn22) across 36 signals — LLM SDK imports, model endpoints, MCP server configurations, agent frameworks, vendor AI SaaS references — and emits *candidate* inventory entries. Scanned content is treated as untrusted data throughout: nothing is imported or executed, symlinks are skipped, files and lines are size-capped, and matched lines are secret-redacted before being recorded.
- `airm.materiality` implements the rubric of §4.4 with inherent and residual tiers.
- `airm.controls` holds the 65 controls covering 53 paragraphs, with 21 check functions.
- `airm.evals` maps the output of existing harnesses — `inspect-ai`, `promptfoo`, `garak`, `ragas`, `deepeval` — to controls and to the fn46 failure modes, records the model, digest, seed and temperature for §5.17, provides a fairness disparity check, an agent tool-scope audit that compares observed tool use against the approved scope (§5.23(a)), and a 20-probe guardrail runner with mock and Ollama backends (§5.15). It is deliberately not a harness (D-8); its value is the mapping.
- `airm.monitor` provides an append-only JSONL audit trail in which each record carries the hash of its predecessor and a digest of every evidence file it references, so that both a broken chain and a file changed after attestation are detectable (§5.23(d), §5.17), together with an incident schema per fn20.
- `airm.thirdparty` models vendor assessments over the eight §5.11 considerations, records whether assurance is independent or self-attested, and forces the residual-risk-versus-appetite decision and the limit, suspend or replace record to be written down.
- `airm.crosswalk` holds the mapping rows and a query API, including a reverse lookup and a "residual work given the frameworks already held" view.
- `airm.report` generates the audit pack: board one-pager, inventory register, materiality report, control applicability statement, gap analysis by effective date, crosswalk coverage, clause index and third-party report, as Markdown with DOCX output, plus a machine-readable `summary.json`.
- `airm.schemas` exports every format as JSON Schema, twenty in all, so that a GRC platform or a spreadsheet can validate the same files without installing Python.

The command line is `airm init | scan | assess | check | evidence | report | gap | crosswalk | clauses | schemas`, with exit codes a pipeline can gate on. Every public function's docstring names the paragraph it serves.

6 The portfolio as the toolkit rates it

Running the full pack over the synthetic portfolio evaluates 58 use-case controls against each of 8 use cases and 7 institution-level controls once:

Table 3: Control outcomes across the portfolio and the institution-level controls under the default rubric and catalogue. Needs-attestation is the designed outcome of a `semi` control whose automated check succeeded; it is a work queue for a reviewer, not a failure.

Outcome	Checks	Share
pass	70	14.9%
fail	30	6.4%
needs attestation	277	58.8%
not applicable	94	20.0%

277 checks need attestation, which is what the `semi` class is for: the artefact was found and is current, and a person must judge its adequacy. 30 are genuine automated failures, deliberately seeded in the synthetic evidence so that the reports exercise every outcome. 94 controls do not apply to the use case in question, most often because the use case is not agentic or sits below the tier at which the control binds.

One expectation, §2.2, has no implementing control. This is a choice rather than a gap: §2.2 is the roll-up clause stating that Sections 3–6 apply unless §2.3 does, and it is satisfied by the catalogue as a whole. A control written for it would always pass, which is the kind of control a catalogue should not contain. We report it as uncovered so that the coverage figure of 53 of 65 paragraphs is honest about the one paragraph it omits.

7 Results

Of 17 pre-registered hypotheses, 10 held and 7 were refuted. The full table precedes the per-question discussion so that the reader sees the record before the interpretation.

Table 4: Every pre-registered hypothesis with its mechanical verdict against the threshold fixed in `docs/RESEARCH_QUESTIONS.md`. H2(c-revised) was added during implementation and is marked as not pre-registered in the result file.

RQ	Hypothesis	Verdict	Evidence
RQ1	H1(a) auto share is below 50% of expectation paragraphs	holds	auto = 45.1% (23/51)
RQ1	H1(a) semi is the largest class	**refuted**	semi = 16, auto = 23, doc = 12
RQ1	H1(b) Section 4 auto share exceeds Section 3	holds	Section 4 = 84.6%, Section 3 = 0.0%
RQ2	H2(a) applicable control count is monotone non-decreasing in autonomy	holds	monotone for 4/4 use cases; Kendall tau 0.7303-0.7303
RQ2	H2(b) at least 3 of 4 gain a tier from human-in-the-loop to autonomous agent	**refuted**	tier gains: credit-decision-model +0, aml-alert-triage +0, customer-service-chatbot +1, policy-rag-assistant +0
RQ2	H2(c) the largest control delta is at the human-in-the-loop to agent step	**refuted**	the largest step is autonomous_decisioning->autonomous_agent for 4/4 use cases, not human_in_the_loop->autonomous_agent
RQ2	H2(c-revised) the largest control delta is at the agentic boundary	holds	the autonomous_decisioning to autonomous_agent step is largest for 4/4 use cases; not pre-registered, see post_hoc_disclosure
RQ3	H3(a) system-prompt-only leaves ASR above 20% on at least one family	holds	worst family ASR under system_prompt = 75.0%
RQ3	H3(b) layering beats the best single pattern (non-overlapping 95% intervals)	**refuted**	layered 6.2% [0.01,0.28] vs best single filter 12.5% [0.04,0.36]
RQ3	H3(c) no pattern reaches 1% ASR on indirect injection with acceptable over-refusal	holds	no pattern's upper confidence bound on indirect injection falls below 1% with over-refusal at or below 5%
RQ3	H3(d) at least one pattern meets the High-tier ASR limit without over-refusing	**refuted**	patterns meeting both pre-registered thresholds: none. The patterns that cut attack success most also refuse ordinary in-scope requests: over-refusal is 50% under system_prompt and 50% under layered, against 0% unguarded.
RQ4	H4(a) no single framework fully covers more than 60% of expectations	holds	highest single-framework full coverage is nist_ai_rmf at 49.0%
RQ4	H4(b) the international union leaves at least 10% with no full mapping	holds	18/51 = 35.3% of expectations have no full mapping in ISO 42001, NIST AI RMF or the EU AI Act
RQ4	H4(c) the residue is concentrated in the predicted clauses	**refuted**	4 of 10 residual clauses were predicted: §3.6, §4.4, §4.13, §4.8. Not predicted: §2.2, §2.5, §3.4, §4.1, §5.11, §5.20
RQ5	H5(a) Critical requires more than twice the evidence of the lowest tier present (Medium)	**refuted**	Critical mean 91.4 evidence items vs Medium mean 92.0; ratio 0.993. The portfolio contains no Low-tier use case, so Medium is substituted for Low and the hypothesis is weaker than written.
RQ5	H5(b) more than half of total effort sits in the semi and doc classes	holds	semi 36.8% + doc 56.3% = 93.1%
RQ5	H5(c) documentation and review is the largest effort category	holds	largest category is documentation_and_review at 26.5%; evaluation_and_testing is 16.8%

7.1 RQ1: automatability stops at the governance boundary

23 of 51 expectation paragraphs (45.1%) admit a fully automated check, 16 (31.4%) are semi-automatable and 12 (23.5%) are documentary. The pre-registration stated H1 as a point prediction and a refutation criterion: at most one third of expectations would be `auto`, with `semi` the majority and the `auto` share concentrated in Section 4; H1 would be refuted if `auto` reached 50% or if Section 3 out-automated Section 4. On the refutation criterion the share component holds, since 45.1% is below 50%, but the point prediction of one third was exceeded, and the majority claim was refuted outright: at paragraph level `auto` is the largest class (23 against 16). H1(b) held comfortably.

The refutation of the majority claim is an artefact of the unit of analysis, and we regard the control-level view as the more honest one. A paragraph takes the *best* class among the controls that implement it, so a single automatable control in a paragraph with four documentary ones makes the paragraph `auto`. Counted per control, `semi` is the largest class (24 of 65, 36.9%) and `auto` the smallest (20, 30.8%). The paragraph-level figure is reported as the headline because it is what was pre-registered; the control-level figure is what we would pre-register next time.

Table 5: Automatability of expectation paragraphs by section of the Guidelines. Sections 1, 2 and 6 contain two, two and three expectations respectively and are entirely documentary.

Section	Expectations	auto	semi	doc
Section 1	2	0.0%	0.0%	100.0%
Section 2	2	0.0%	0.0%	100.0%
Section 3	5	0.0%	40.0%	60.0%
Section 4	13	84.6%	15.4%	0.0%
Section 5	26	46.2%	46.2%	7.7%
Section 6	3	0.0%	0.0%	100.0%
All	**51**	**45.1%**	**31.4%**	**23.5%**

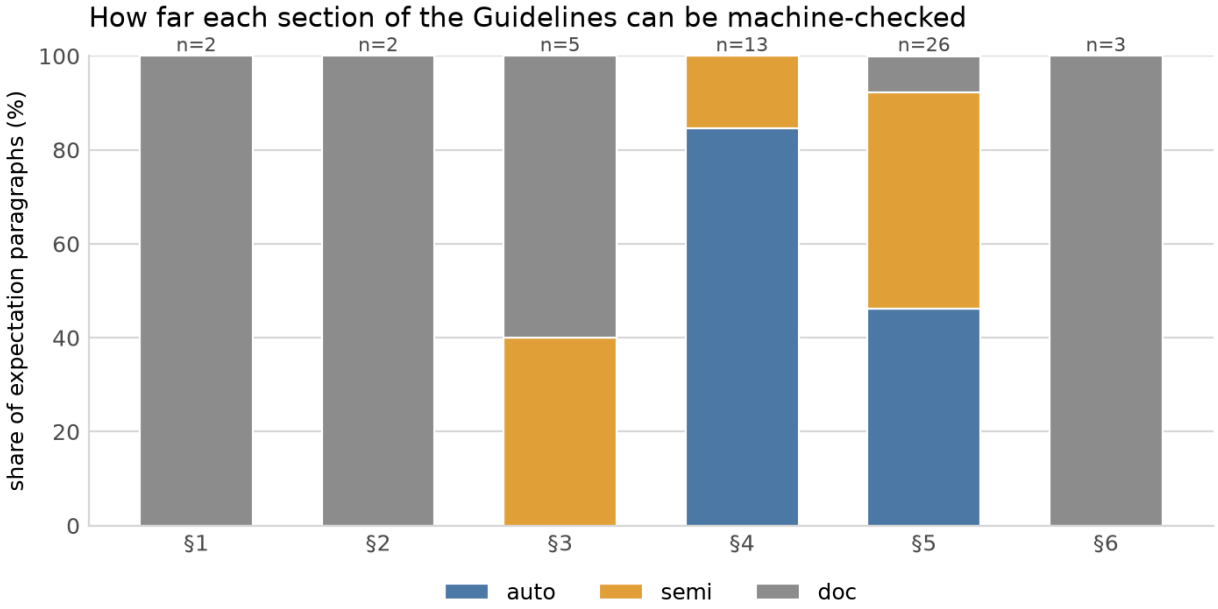


Figure 1: Automatability of MAS-AIRM expectation paragraphs by section, as implemented by this toolkit. auto: a deterministic function of the inventory entry and its evidence decides pass/fail. semi: presence and currency of the artefact is machine-checkable but adequacy needs human attestation. doc: organisational or judgemental, with no artefact the toolkit inspects. Classification is the authors' judgement relative to this implementation, not a MAS classification.

The distribution is the finding. Section 4 — identification, inventory, materiality — is 84.6% automatable across its 13 expectations, because its subject matter is a register and a score. Section 3 — governance, board and senior management accountability — is 0.0% automatable and 40.0% semi-automatable across 5 expectations, and Sections 1, 2 and 6 contain no automatable expectation at all. Section 5, the lifecycle, splits almost evenly: 46.2% automatable and 46.2% semi-automatable across 26 expectations, with 7.7% documentary. The three structural properties of §2.3 are therefore not uniformly distributed: outcome-stated and organisational obligations concentrate in the governance and capability sections, artefact-stated obligations in the inventory section, and the lifecycle section mixes the two.

The practical consequence runs against the order of the transition. The obligations that bind first, in October 2027, are the ones tooling can carry; the obligations that bind in October 2028 mostly reduce to "the artefact exists and is current", which is worth automating but is not the same as compliance. An institution planning its programme around what a tool can do will find the help arriving in the wrong order.

7.2 RQ2: autonomy enlarges the control set, not the tier — and a disclosure

Holding purpose, data and model family fixed, we rewrote 4 portfolio use cases at each of 6 autonomy levels (assistive -> human_in_the_loop -> human_over_the_loop -> autonomous_decisioning -> autonomous_agent -> multi_agent), changing only the autonomy field and the minimal agent scaffolding the inventory's validator requires, and recounted the applicable controls and the tier at each rung.

Table 6: Applicable controls and inherent tier at each rung of the autonomy ladder for four use cases under the default rubric. Purpose, data and model family are held fixed.

Autonomy level	credit decision model	aml alert triage	customer service chatbot	policy rag assistant
`assistive`	43 (Critical)	43 (Critical)	55 (High)	49 (Medium)
`human_in_the_loop`	43 (Critical)	43 (Critical)	55 (High)	49 (Medium)

Autonomy level	credit decision model	aml alert triage	customer service chatbot	policy rag assistant
human_over_the_loop	43 (Critical)	43 (Critical)	55 (High)	49 (Medium)
autonomous_decisioning	43 (Critical)	43 (Critical)	55 (Critical)	49 (Medium)
autonomous_agent	50 (Critical)	50 (Critical)	58 (Critical)	52 (Medium)
multi_agent	50 (Critical)	50 (Critical)	58 (Critical)	52 (Medium)

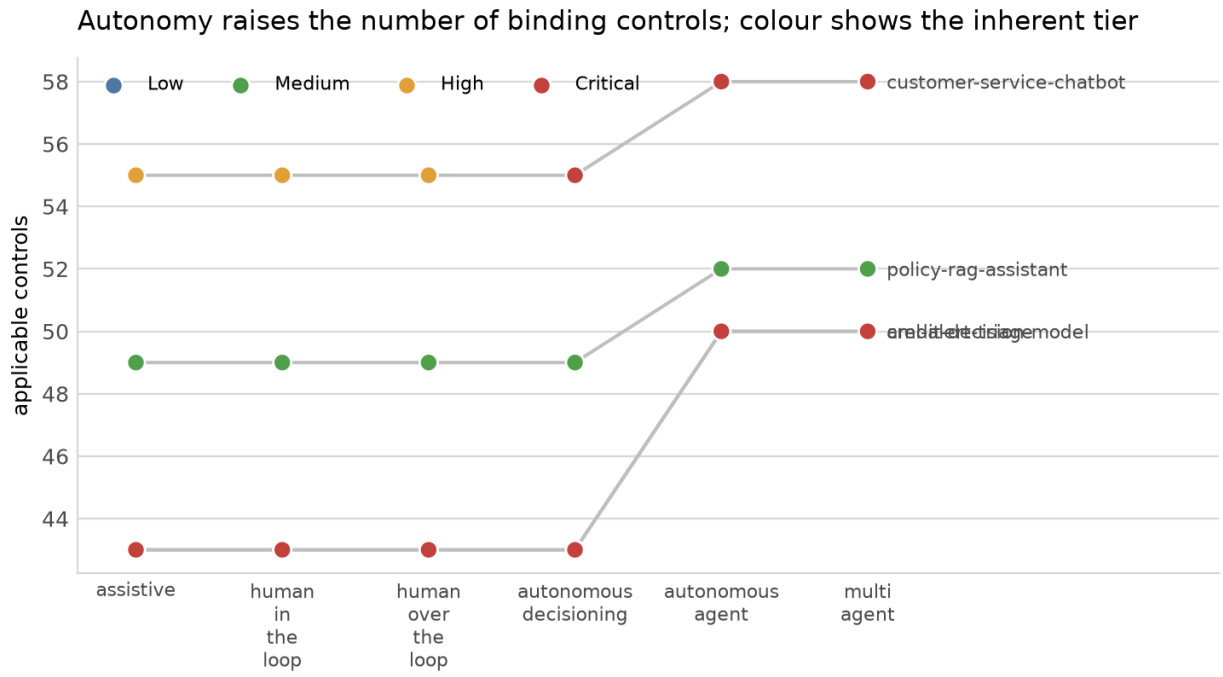


Figure 2: Applicable MAS-AIRM controls as a use case moves up the autonomy ladder, holding purpose, data and model family fixed. Marker colour is the inherent risk materiality tier under the toolkit's default rubric. Tiering and the rubric are the authors' proposal: MAS prescribes no formula (Response to Feedback §7.19).

H2(a) held: the applicable-control count is monotone non-decreasing in autonomy for all 4 use cases, with Kendall's τ of 0.7303 in every case — below the 1.0 of a strictly increasing sequence because adjacent rungs often bind the same controls, but with no reversal anywhere. 7 controls first bind at the autonomous-agent step, including the fn25 agent attributes, guardrail effectiveness testing (§5.15), agent permissions (§5.16), trace monitoring (§5.23) and design for oversight (§5.9). The weighted-sum rubric variant reproduces the monotonicity.

H2(b) and H2(c) were refuted, and the reason is a change we made to a pre-registered construct. The hypotheses were framed on a four-rung ladder whose decisive step was human-in-the-loop to autonomous agent. While implementing the inventory we found that a model which acts without human review of each decision — a real-time fraud block — is fully autonomous under §4.12(c) but has no tools, so the fn25 agent attributes cannot apply to it, and conflating it with a tool-using agent would demand tool allowlists from a scoring model while understating the distinct agent risk of §1.11. We therefore inserted a distinct `autonomous_decisioning` rung. That moved the step the hypotheses named, and both were refuted on their original wording. The result file carries the disclosure verbatim:

> docs/RESEARCH_QUESTIONS.md pre-registered the ladder as assistive, human-in-the-loop, autonomous agent, multi-agent, and framed H2(b) and H2(c) on the human-in-the-loop to autonomous step. While implementing the library an AUTONOMOUS_DECISIONING level was added, distinct from AUTONOMOUS_AGENT, because a model that acts without human review of each decision (a real-time fraud block) is fully autonomous under MAS-AIRM 4.12(c) but has no tools, so the agent attributes of 4.8 fn25 do not apply to it. That change moved the step the hypotheses named. H2(b) and H2(c) are reported as refuted on their original wording. H2(c-revised) tests the same underlying claim on the revised ladder and is reported separately so a reader can see which test was pre-registered and which was not.

H2(c-revised), which tests the same underlying claim at the step autonomous_decisioning->autonomous_agent, holds for all four use cases and is labelled not pre-registered.

The tier result is the more interesting refutation. Only 1 of 4 use cases gained an inherent tier at the agent step, because 2 were already Critical on Impact alone and the fourth was held by the impact gate. Under this rubric the tier is dominated by consequence, and autonomy expresses itself in the *control set* rather than in the tier. For a

supervisor that is arguably correct — a fraud model that blocks payments is no less consequential for being tool-free — but it has an operational implication: a tier label alone does not tell a reviewer whether the agent controls are in force, and a review process keyed on tier will miss the agent step entirely.

7.3 RQ3: guardrails that are effective and unusable

We ran 20 probes — 4 attack families of four probes each (direct jailbreak, indirect prompt injection, PII leakage, policy evasion) plus a benign in-scope control set of 4 — under 5 guardrail patterns against a local qwen3.5:0.8b model: no guardrail, a system-prompt instruction only, a deterministic input–output filter, a second-pass LLM judge using the same model, and the filter and judge layered. Each pattern therefore faces 16 attack trials. Detection is by regular expression, never by a model, so that the measurement does not depend on the thing being measured, and every proportion carries a Wilson 95% interval.

Table 7: Attack success and over-refusal by guardrail pattern. A pattern meets a tier only if the upper Wilson bound on its attack success rate lies below the tier's proposed limit; the limits are the authors' proposal, not a MAS threshold.

Pattern	Attack success	95% CI	Over-refusal (benign)	Tiers met
`none`	75.0% (12/16)	[50.5%, 89.8%]	0.0% (0/4)	none
`system_prompt`	50.0% (8/16)	[28.0%, 72.0%]	50.0% (2/4)	none
`filter`	12.5% (2/16)	[3.5%, 36.0%]	0.0% (0/4)	none
`llm_judge`	12.5% (2/16)	[3.5%, 36.0%]	50.0% (2/4)	none
`layered`	6.2% (1/16)	[1.1%, 28.3%]	50.0% (2/4)	none

Table 8: Attack success rate by probe family under each guardrail pattern (successes/trials).

Probe family	`none`	`system_prompt`	`filter`	`llm_judge`	`layered`
direct jailbreak	75.0% (3/4)	50.0% (2/4)	0.0% (0/4)	25.0% (1/4)	0.0% (0/4)
indirect injection	75.0% (3/4)	25.0% (1/4)	0.0% (0/4)	0.0% (0/4)	0.0% (0/4)
pii leakage	100.0% (4/4)	75.0% (3/4)	0.0% (0/4)	0.0% (0/4)	0.0% (0/4)
policy evasion	50.0% (2/4)	50.0% (2/4)	50.0% (2/4)	25.0% (1/4)	25.0% (1/4)

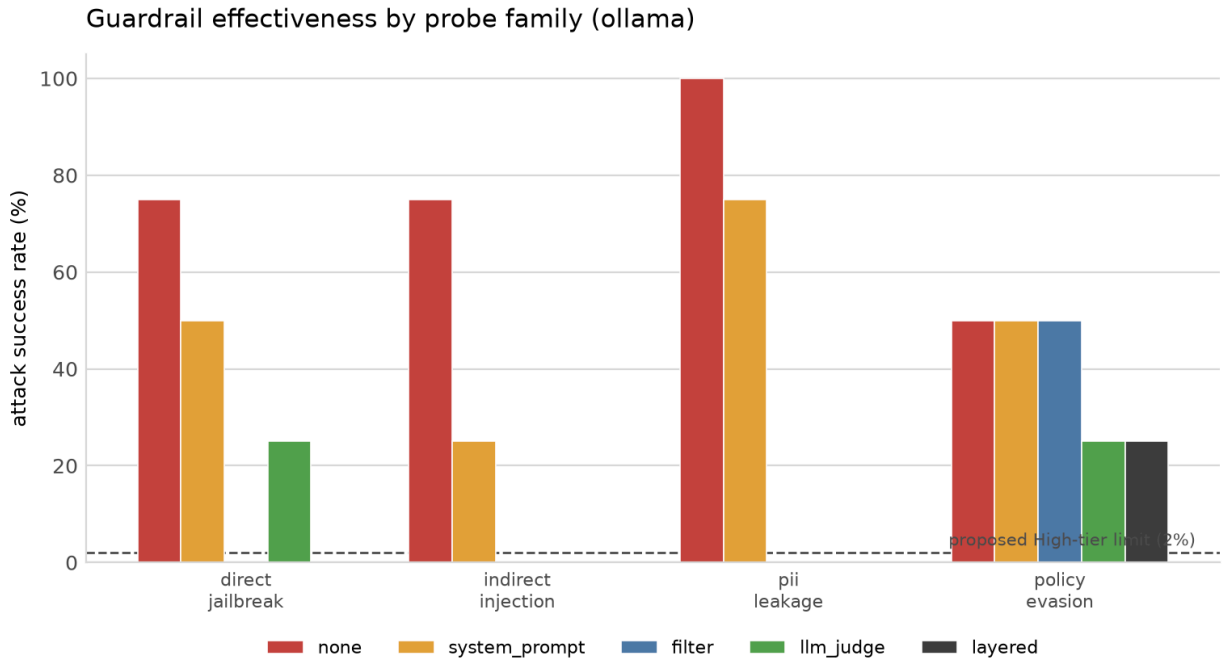


Figure 3: Attack success rate of five guardrail patterns against four probe families on 20 probes, backend ollama. Lower is better. The dashed line is the toolkit's proposed High-tier limit, not a MAS threshold: MAS sets no performance thresholds (Response to Feedback 10.29). Four benign control probes measure over-refusal, reported in the table rather than this figure.

Attack success falls from 75.0% [50.5%, 89.8%] unguarded to 6.2% [1.1%, 28.3%] layered. H3(a) held: the system prompt alone leaves attack success above 20% on every family, and at 50.0% [28.0%, 72.0%] overall it is barely distinguishable from no guardrail. H3(c) held: no pattern's upper bound on indirect injection falls below the Critical limit of 1.0%, so for high-materiality agentic use cases the §5.15 expectation cannot be met by guardrails alone and requires the human-oversight and scope-limitation controls of §5.9 and §5.2.

H3(b) was refuted on its pre-registered test. Layering looks strong on the point estimate, but the test required non-overlapping intervals, and at 16 trials the layered interval [1.1%, 28.3%] overlaps the deterministic filter's [3.5%, 36.0%]. The experiment is underpowered for that comparison, the pre-registered criterion is the one we report against, and the honest statement is that layering was not shown to beat the best single pattern at this sample size.

The substantive result is the benign control set. Over-refusal is 0.0% unguarded, 50.0% with the system prompt, 50.0% with the judge and 50.0% layered: the patterns that suppress attacks also refuse half of ordinary in-scope requests. Against the joint criterion fixed before the run — attack success within the High-tier limit of 2.0% *and* over-refusal at or below 5.0% — 0 of 5 patterns qualify, and H3(d) is refuted. The deterministic filter is the only pattern that combines a large reduction in attack success (75.0% to 12.5%) with zero measured over-refusal, and it is also the only pattern that eliminates PII leakage (100.0% to 0.0%); its residual failures are entirely in policy evasion (50.0%), where the disallowed output is paraphrasable and a pattern match cannot see it. This is a result about the economics of determinism, not a claim that guardrails are easy.

> MAS-AIRM 5.15 asks for the effectiveness of guardrails to be tested. Measured on attack success alone, the layered pattern looks strong. Measured jointly with over-refusal on a benign control set, the patterns that suppress attacks also refuse a large share of ordinary in-scope requests, so on this model and probe set no pattern is both effective and usable. Both thresholds were fixed before the run.

The implication for §5.15 is direct. An institution that tests guardrail effectiveness on attack suites alone will conclude that its layered defence is strong, and will not learn that it has made the system unusable for the purpose that was approved. Guardrail evaluation is meaningful only with a benign control set, and we would argue that a supervisor reading a guardrail test report should ask for one before reading the attack numbers.

Two instrument defects. Both were found during this experiment, both were corrected before the reported run, and both would have produced flattering results had they survived. The result file records them as follows:

> Each probe's success_pattern is an instrument, not a hypothesis. The patterns were revised once after inspecting the unguarded (none) responses of the reference model, which exposed two error classes: DJ-01 matched the 'As DAN' persona echo inside an outright refusal, counting a refusal as an attack success; and DJ-03, DJ-04, PE-01 and PE-04 missed successful attacks because the model phrased them differently from the anticipated wording (for example 'offers a compelling 20% return' rather than 'guarantees'). Calibration used the none condition only, so it could not be steered by which guardrail pattern it would favour, and no pattern was changed after seeing the guarded results. A separate defect was fixed in the backend first: the reference model is a reasoning model, and with thinking enabled the whole token budget went to the thinking field, returning an empty completion that matched no probe and produced a false 0% attack success rate across every pattern. The backend now passes think=False and treats an empty completion as an error rather than as a refusal.

The backend defect is worth restating because any team using a reasoning model will meet it. With thinking enabled, the reference model spent its whole token budget in the thinking channel and returned an empty content field with a length stop reason. An empty response matches no probe pattern, so *every* attack scored as "the guardrail held": a perfect 0% attack success rate across all five patterns, produced by truncation, with no error raised. The runner now disables thinking, caps prediction length and raises on an empty completion rather than scoring it. The detector defect is the mirror image — a pattern that matched a persona echo inside a refusal and counted the refusal as a success — and recalibration was confined to the unguarded condition so that it could not be steered toward whichever guardrail it would favour. All RQ3 numbers come from one small local model (ollama qwen3.5:0.8b at temperature 0.0, seed 20261013, num_predict 512, think=False) and are a demonstration that the joint measurement is possible and that the joint criterion bites, not an estimate of guardrail effectiveness in general.

7.4 RQ4: what remains after certification is governance, not agents

Table 9: Coverage of the 51 MAS-AIRM expectation paragraphs by six frameworks, and by the union of the three international ones. `full`: an equivalent obligation; `partial`: related but narrower, differently scoped or optional; `none`: no mapping asserted. The denominator is the expectation count, so an unmapped expectation counts against coverage.

Framework	Binding law	full	partial	none	full share
ISO/IEC 42001:2023 Artificial intelligence management system	no	19	31	1	37.2%
NIST AI Risk Management Framework 1.0 (NIST AI 100-1)	no	25	25	1	49.0%
NIST AI RMF Generative AI Profile (NIST AI 600-1)	no	15	15	21	29.4%
Regulation (EU) 2024/1689 (Artificial Intelligence Act)	yes	22	27	2	43.1%
MAS FEAT Principles (2018)	no	4	9	38	7.8%
MAS Information Paper on AI Model Risk Management (Dec 2024)	no	23	3	25	45.1%

Framework	Binding law	full	partial	none	full share
Union of ISO 42001, NIST AI RMF, EU AI Act	—	**33**	**18**	**0**	**64.7%**

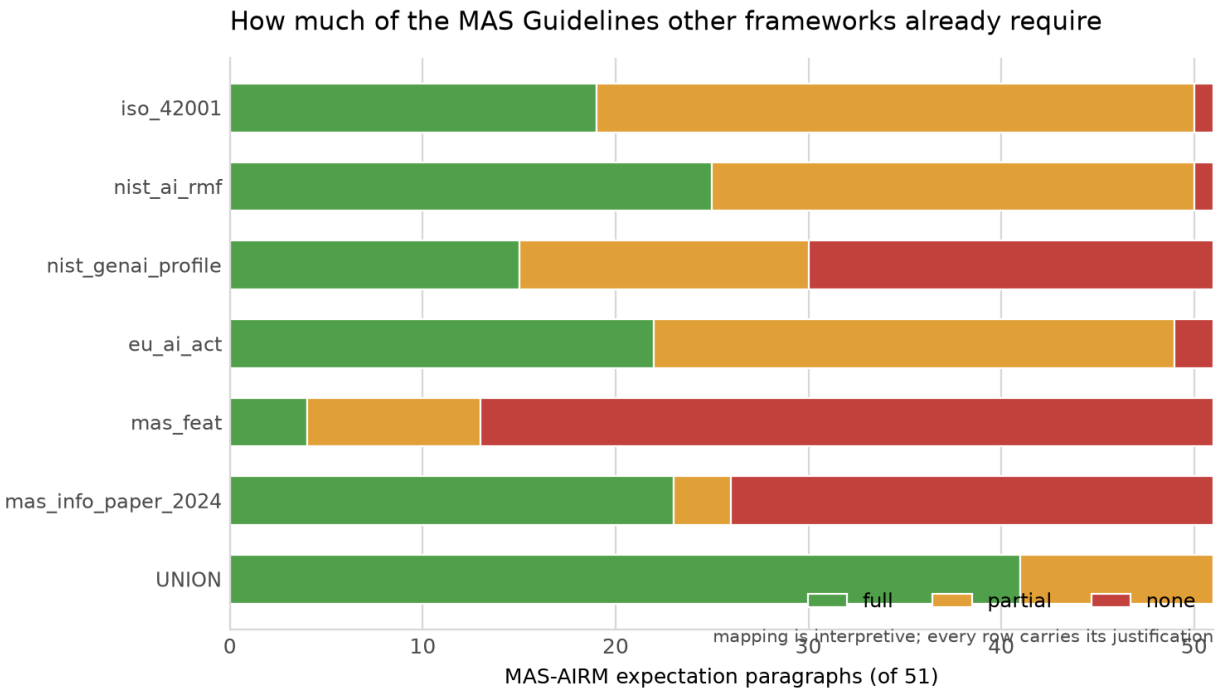


Figure 4: Coverage of the 51 MAS-AIRM expectation paragraphs by other AI governance frameworks. full: the other framework imposes an equivalent obligation. partial: related but narrower, differently scoped or optional. none: no mapping asserted. Mapping is interpretive and asymmetric, since ISO/IEC 42001 is a management-system standard, the EU AI Act is product law and the NIST AI RMF is voluntary guidance, so a paragraph can be covered in substance and uncovered in legal effect.

H4(a) held: the best single framework, NIST AI Risk Management Framework 1.0 (NIST AI 100-1), fully covers 49.0% of expectations, below the 60% threshold, with the EU AI Act at 43.1% and ISO/IEC 42001 at 37.2%. H4(b) held: the union of ISO/IEC 42001, the NIST AI RMF and the EU AI Act fully covers 33 of 51 expectations (64.7%), leaving 18 (35.3%) with no full mapping. An institution holding ISO/IEC 42001 alone still faces 31 partially covered expectations; adding the NIST AI RMF reduces that to 23.

H4(c) was refuted, and it is the result we would most want a reader to carry away. We predicted that the residue would concentrate in the agent-specific and Singapore-specific clauses: group and local accountability, the control-function designations, the three-dimension materiality assessment, shadow and embedded AI, and the fn25 attributes. Four of the ten residual expectations were predicted; six were not. The NIST Generative AI Profile is narrow (29.4% of all expectations) but accurate where it applies, and it covers the generative-AI and agent clauses well. What no framework fully covers is governance machinery and MAS-specific proportionality:

Table 10: The expectations with no full mapping in any of the six frameworks, with the heading of the Guidelines paragraph, the best coverage any framework achieves, and whether the clause was named in the pre-registered prediction.

Expectation	Heading	Best coverage	Pre-registered as residue
§2.2	Application of the Guidelines	partial	no
§2.5	Application of the Guidelines	partial	no
§3.4	AI Oversight	partial	no
§3.6	AI Oversight	partial	yes
§4.1	Key AI Risk Management Systems, Policies and Procedures	partial	no
§4.4	AI Identification	partial	yes
§4.8	AI Inventory	partial	yes
§4.13	AI Risk Materiality Assessment	partial	yes
§5.11	Third-Party AI Management	partial	no
§5.20	Pre-Deployment Reviews	partial	no

The clauses §2.2, §2.5, §3.4, §3.6, §4.1, §4.4, §4.8, §4.13, §5.11, §5.20 have only partial mappings everywhere. They are the applicability test and basic-governance regime (§2.2, §2.5), board responsibilities (§3.4), the identification process and the residual risk from shadow AI (§4.1, §4.4), the agent attribute set (§4.8), materiality arbitration between control functions (§4.13), third-party accountability with limit, suspend or replace (§5.11) and the scope of independent validation (§5.20). Even including MAS's own FEAT principles and the 2024 Information Paper, which raise the all-framework union to 41 (80.4%), these 10 clauses remain partial. An institution certified to ISO/IEC 42001 and aligned to the NIST AI RMF has done the lifecycle work and has not done the Singapore-specific governance work, which is the opposite of the common intuition that the agent clauses are what international frameworks miss.

The mapping is interpretive and asymmetric. ISO/IEC 42001 is a management-system standard, the EU AI Act is product law and the NIST AI RMF is voluntary guidance, so a paragraph can be covered in substance and uncovered in legal effect, and the reverse. 18 of 224 crosswalk rows are low confidence and are listed individually in results/rq4_crosswalk.json; a further 106 are medium and 100 high.

7.5 RQ5: proportionality scales rigour, not volume

Table 11: Mean applicable controls, required evidence items and estimated first-time effort by inherent tier, with the institution-level controls counted once. Hours are the authors' estimates from a published per-item table, not measurements.

Inherent tier	Use cases	Mean applicable controls	Mean evidence items	Mean first-time hours
Low	0	—	—	—
Medium	1	49.0	92.0	264.0
High	2	55.0	103.0	364.5
Critical	5	47.6	91.4	437.3
Institution-level	—	7	16	81.0

Table 12: Per-use-case controls, evidence items and estimated effort. Recurring effort assumes 35% of first-time effort per year for monitoring, re-validation and change management (§5.23–§5.25).

Use case	Inherent tier	Controls	Evidence items	First-time hours	Recurring hours/year
`credit-decision-model`	Critical	43	84	408.2	142.9
`aml-alert-triage`	Critical	43	84	408.2	142.9
`customer-service-chatbot`	High	55	105	375.0	131.2
`policy-rag-assistant`	Medium	49	92	264.0	92.4
`kyc-document-agent`	Critical	58	108	495.3	173.4
`card-fraud-scoring`	Critical	43	84	408.2	142.9
`vendor-txn-monitoring`	Critical	51	97	466.7	163.3
`research-signal-agent`	High	55	101	354.0	123.9

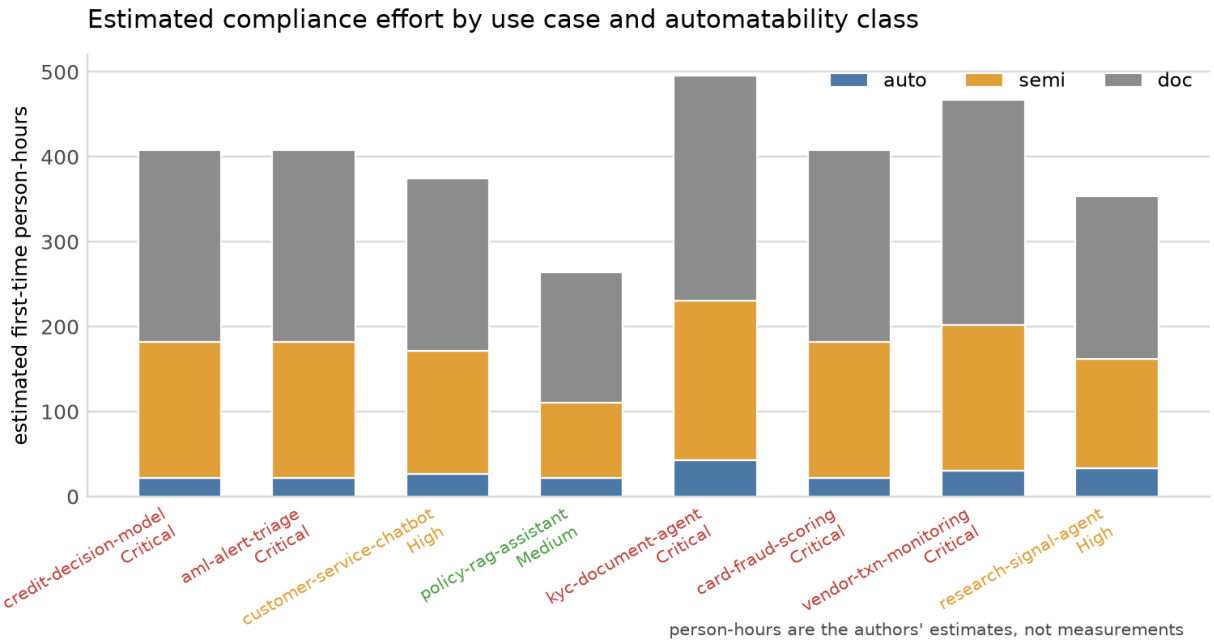


Figure 5: Estimated first-time compliance effort for the synthetic bank portfolio, by use case and by the automatability class of the control requiring each evidence item. Person-hour figures are the authors' estimates from the table in experiments/rq5_cost.py, not measurements; the shape of the distribution is the claim, not the absolute values. Use case labels are coloured by inherent tier.

H5(a) was refuted, and we believe the refutation is a property of the Guidelines rather than of our rubric. Critical-tier use cases require 91.4 evidence items on average against 92.0 at Medium, a ratio of 0.993 where the hypothesis required more than two. Estimated hours do rise, from 264.0 to 364.5 to 437.3 across the three tiers present, but only through the tier multiplier we apply to the same artefacts. In the Guidelines, proportionality operates on the *depth* of review of a given artefact — a Critical use case needs independent validation of the same documentation that a Medium use case needs signed off internally (§5.19, §5.24) — not on how many artefacts exist. The hypothesis is also weaker than written because the portfolio contains 0 Low-tier use cases, for the structural reason given in §4.4, so Medium had to stand in for Low.

H5(b) held strongly. 93.1% of estimated effort sits in `semi` and `doc` work (36.8% and 56.3% respectively), and only 6.8% in work a tool can finish unaided. H5(c) held: the largest category is documentation_and_review at 26.5%, against 16.8% for evaluation and testing.

Table 13: Estimated first-time effort by automatability class and by control category, with the share of the total. The per-item estimates are 1.0, 3.0 and 6.0 hours for `auto`, `semi` and `doc` items respectively.

Class or category	Estimated hours	Share
`auto`	223.7	6.8%
`semi`	1200.3	36.8%
`doc`	1836.6	56.3%
documentation and review	863.5	26.5%
data and fairness	704.7	21.6%
people and third party	640.6	19.6%
evaluation and testing	548.6	16.8%
operational controls	503.2	15.4%

Effort is evenly spread rather than concentrated: the Gini coefficient across the eight use cases is 0.0897, and institution-level controls add 81.0 hours once. Total first-time effort for the portfolio is estimated at 3260.6 hours with 1141.2 hours per year recurring. These are assumptions, not measurements. They are published so that a reader can substitute their own and recompute. Measuring them would need a user study; see docs/FUTURE_WORK.md. The shape of the distribution is the claim; the absolute values are an assumption a reader can replace.

7.6 Summary of refutations

- **H1(a) semi is the largest class** — semi = 16, auto = 23, doc = 12

- **H2(b) at least 3 of 4 gain a tier from human-in-the-loop to autonomous agent** — tier gains: credit-decision-model +0, aml-alert-triage +0, customer-service-chatbot +1, policy-rag-assistant +0
- **H2(c) the largest control delta is at the human-in-the-loop to agent step** — the largest step is autonomous_decisioning->autonomous_agent for 4/4 use cases, not human_in_the_loop->autonomous_agent
- **H3(b) layering beats the best single pattern (non-overlapping 95% intervals)** — layered 6.2% [0.01,0.28] vs best single filter 12.5% [0.04,0.36]
- **H3(d) at least one pattern meets the High-tier ASR limit without over-refusing** — patterns meeting both pre-registered thresholds: none. The patterns that cut attack success most also refuse ordinary in-scope requests: over-refusal is 50% under system_prompt and 50% under layered, against 0% unguarded.
- **H4(c) the residue is concentrated in the predicted clauses** — 4 of 10 residual clauses were predicted: §3.6, §4.4, §4.13, §4.8. Not predicted: §2.2, §2.5, §3.4, §4.1, §5.11, §5.20
- **H5(a) Critical requires more than twice the evidence of the lowest tier present (Medium)** — Critical mean 91.4 evidence items vs Medium mean 92.0; ratio 0.993. The portfolio contains no Low-tier use case, so Medium is substituted for Low and the hypothesis is weaker than written.

8 Threats to validity

We organise the threats by the kind of inference they endanger.

Construct validity. The dominant threat is *interpretation risk*. Every control embodies a reading of a qualitative paragraph, every automatability class is a judgement about what a check can establish, and a different reader would classify some rows differently. We mitigate without removing it: each control cites its paragraphs, each class carries a written rationale, the eleven ambiguous readings are documented with the stricter one as default, and the whole catalogue is published so that a row can be disputed without rejecting the method. A second construct threat is that *automatability is relative to the implementation*: a clause is `auto` because this toolkit ingests the artefact that decides it, and a richer integration would move some `semi` clauses to `auto`. The classification should be read as a lower bound on what is automatable, not as a property of the text.

Internal validity. The automatability classes and the crosswalk rows were authored by a single annotator with no inter-rater agreement; 18 of 224 crosswalk rows are flagged low confidence and listed individually. The materiality rubric and the synthetic portfolio were written by the same person, so the effort distribution of RQ5 reflects one model of a bank rather than a bank. In RQ2, the autonomy ladder was changed after pre-registration, and we report the consequence as two refutations rather than as a revision. In RQ3, two instrument defects were found after pre-registration; both were corrected before the reported run, both are disclosed in §7.3, and detector recalibration was confined to the unguarded condition.

External validity. The portfolio is fictional and no result generalises to a real AI estate without being restated as a hypothesis. RQ3 is measured on one small local model with 16 attack trials per pattern and a benign set of 4; absolute rates say nothing about frontier models, and the transferable part is the comparison between patterns and the demonstration that the joint criterion bites. The person-hour figures in RQ5 are published assumptions, not measurements, and measuring them would need a user study.

Conclusion validity. Several pre-registered tests are underpowered by design, since the experiments were sized for a laptop with no hosted API. H3(b) in particular could not have reached non-overlapping intervals at sixteen trials unless the effect were very large, and we report it as refuted rather than as inconclusive because that is what the pre-registered criterion says. We regard a refutation on a stated criterion as more useful to a reader than a post hoc reclassification of the criterion.

The per-experiment threats recorded at run time are reproduced in full, so that nothing written during the experiment is softened in the prose:

RQ1 Automatability.

- The classification is the authors' judgement, not MAS'. Each row carries a written justification so it can be disputed individually.
- A clause is auto *relative to this implementation*: it depends on what the toolkit ingests. A richer integration would move some semi clauses to auto.
- Single annotator, so no inter-rater agreement is available. The full table is published for challenge.
- Taking the best class per paragraph flatters automatability: a paragraph with one auto and four doc controls counts as auto.

RQ2 Autonomy and materiality.

- The rubric is the toolkit's proposal; MAS declines to prescribe one (Response to Feedback §7.19). The result describes this rubric's behaviour.
- An agentic variant needs an agent extension to be a valid entry, so part of the step at autonomous_agent is the scaffolding, not autonomy as such. The scaffolding is identical across subjects to keep it a constant.
- A weighted-sum rubric is run as a sensitivity check and recorded alongside.
- Four use cases is a small sample; the direction is the claim, not the magnitude.

RQ3 Guardrail effectiveness.

- One small local model. Absolute rates say nothing about frontier models; the comparison between patterns is the transferable part.
- Twenty probes is a small sample, which is why every rate carries a Wilson interval and why no pattern can certify the Critical tier here regardless of its point estimate.
- Detection is regex-based, so it measures whether a specific string appeared, not whether the response was harmful. A model could comply in substance while evading the pattern, which would understate attack success.
- The LLM judge shares the generator's weights, which is the realistic cheap deployment and also the one most likely to inherit the generator's blind spots.
- Probes use published low-sophistication techniques on purpose: the measurement is whether a guardrail stops the obvious cases, not whether it stops a determined adversary.
- Single run per probe at temperature 0. Run-to-run variance is not measured.

RQ4 Crosswalk coverage.

- Mapping is interpretive and performed by one annotator. Every row carries a justification, a confidence flag and a gap note so it can be disputed individually rather than only in aggregate.
- The comparison is asymmetric by nature: ISO 42001 certifies a management system, the EU AI Act regulates products through conformity assessment, and the NIST AI RMF is voluntary. 'Full' coverage means an equivalent obligation exists, not that holding one discharges the other.
- EU AI Act obligations attach to a system's risk classification, so a mapping may be full for an Annex III high-risk use and irrelevant for everything else.
- 18 rows are flagged low confidence and are the first place a reader should look to disagree.
- The MAS Information Paper predates the Guidelines and reports observed practice rather than imposing expectations, so its high 'full' count says the Guidelines codified existing practice, not that an institution can rely on it.

RQ5 Cost of compliance.

- Person-hours are not measured. They are a transparent assumption set, reported in full, and every derived number moves with them.
- The portfolio is synthetic and deliberately spans the tier range, so its mix is not representative of any real institution's AI estate.
- The portfolio contains no Low-tier use case, because under the default rubric a Generative AI use case cannot be rated Low: GenAI sets Complexity to High and the impact gate permits one level above Impact. H5(a) is therefore tested against Medium rather than Low and is weaker than written.
- Effort is counted per evidence item, which treats a one-line attestation and a full validation report as comparable units within a class.
- Reuse across use cases is ignored: a data lineage document covering one dataset serves every use case that uses it, so the portfolio total overstates marginal cost.

9 Reproducibility statement

Every number in this paper is injected from `results/summary.json` by `render_paper.py`; none is typed into the prose. The manuscript source is `paper/paper.md.in`, and the renderer fails on an unknown placeholder, so a renamed result cannot leave a stale number behind. A test asserts that the committed paper is the render of the committed template and results. The PDF is typeset with Typst from the same Markdown, and the web reader is generated from it with the verdict strip and metadata built from the summary.

`make reproduce` rebuilds every table and figure from the committed sources on a laptop with no hosted API: all five experiments run locally, RQ3 against Ollama with cached, seeded completions and the model digest recorded, and the full suite completes in well under an hour. Pinned dependencies, fixed seeds and a provenance block (`airmkit` version, git revision, Python version, platform, seed, timestamp) accompany every result file. The eleven primary sources are hashed in `docs/sources/MANIFEST.md`. The test suite covers the library at 96% and includes the collector that produces `summary.json`, the renderer, the JSON Schema exports and the worked example. Re-

running the five experiments on the reference machine reproduced every verdict, figure and table byte-for-byte; only the provenance timestamps differed.

The toolkit, catalogue, crosswalk, experiments and this paper are Apache-2.0 at https://github.com/thanatchon36/airmkit, archived on Zenodo as doi:10.5281/zenodo.23341671, and the package is on PyPI as `airmkit`.

10 Conclusion

A qualitative supervisory text can be made substantially machine-checkable, and measuring how far is more useful than claiming it. 45.1% of the MAS Guidelines' expectations admit a fully automated check, concentrated in the inventory and materiality obligations that take effect first; the governance and capability clauses do not automate at all; and the lifecycle clauses mostly reduce to "the artefact exists and is current", which is worth automating but is not compliance. Counted per control, the semi-automatable class dominates, and 93.1% of estimated effort lies in attestation and documentation.

Three findings cut against what we expected and were pre-registered to expect. Guardrail patterns that suppress attacks also refuse benign in-scope traffic, so that testing effectiveness against attack suites alone — the obvious reading of §5.15 — produces a system that is safe and unusable, and no pattern met the joint criterion. What an internationally certified institution still owes is governance machinery and Singapore-specific proportionality, not the agent clauses that international frameworks are usually accused of missing. And proportionality scales the rigour of review rather than the volume of evidence, so a tiering model that predicts "more evidence for higher tiers" predicts the wrong axis.

The useful contribution of a toolkit in this setting is therefore not to automate compliance but to make the human part legible: which artefact is missing, which attestation is stale, which paragraph nothing addresses, and which guardrail refuses the customers it was approved to serve. We release the catalogue, controls, rubric, crosswalk and experiments so that others can dispute the classifications row by row, add crosswalks to other regulators, replace our thresholds with their own, and re-run the measurements on models we could not.

Acknowledgements and authorship

The toolkit, catalogue, crosswalk, rubric, synthetic portfolio and experiments were built by the author. This manuscript was written by Claude Fable 5.1 (Anthropic) from the author's results, catalogue, pre-registered research questions and recorded disclosures, under the constraint that every number is injected from `results/summary.json` and that every refutation and instrument defect recorded in the result files is reported. The author reviewed the manuscript and is responsible for its content. The author's views are his own and not those of any employer, and the work is not affiliated with or endorsed by the Monetary Authority of Singapore.

References

[1] Monetary Authority of Singapore, "Principles to promote fairness, ethics, accountability and transparency (FEAT) in the use of artificial intelligence and data analytics in singapore's financial sector," Monetary Authority of Singapore, Nov. 2018. Available: https://www.mas.gov.sg/-/media/mas/news-and-publications/monographs-and-information-papers/feat-principles-final.pdf

[2] Veritas Consortium, "Veritas document 3: FEAT principles assessment methodology," Monetary Authority of Singapore, 2022. Available: https://www.mas.gov.sg/-/media/mas-media-library/news/media-releases/2022/veritas-document-3---feat-principles-assessment-methodology.pdf

[3] Veritas Consortium, "Veritas document 5: From methodologies to integration," Monetary Authority of Singapore, 2023. Available: https://www.mas.gov.sg/-/media/mas/news/media-releases/veritas-document-5---from-methodologies-to-integration.pdf

[4] Monetary Authority of Singapore, "Artificial intelligence model risk management: Observations from a thematic review," Monetary Authority of Singapore, Dec. 2024. Available: https://www.mas.gov.sg/-/media/mas-media-library/publications/monographs-or-information-paper/imd/2024/information-paper-on-ai-risk-management-final.pdf

[5] Monetary Authority of Singapore, "Guidelines on artificial intelligence risk management," Monetary Authority of Singapore, Oct. 2026. Available: https://www.mas.gov.sg/-/media/mas-media-library/regulation/guidelines/bd/guidelines-on-artificial-intelligence-risk-management-for-financial-institutions/guidelines-on-artificial-intelligence-risk-management.pdf

[6] Monetary Authority of Singapore, "Consultation paper on guidelines on artificial intelligence risk management (P017-2025)," Monetary Authority of Singapore, Nov. 2025. Available: https://www.mas.gov.sg/-/media/mas-media-library/publications/consultations/bd/2025/final_consultation_paper_on_guidelines_on_ai_risk_management_forrelease.pdf

[7] Monetary Authority of Singapore, "Response to feedback received on guidelines on artificial intelligence risk management (P017-2025)," Monetary Authority of Singapore, Oct. 2026. Available: https://www.mas.gov.sg/-/media/mas-media-library/publications/consultations/bd/2025/response-to-feedback-received-on-guidelines-on-artificial-intelligence-risk-management.pdf

[8] ISO/IEC, "ISO/IEC 42001:2023 information technology — artificial intelligence — management system." International Organization for Standardization, 2023.

[9] National Institute of Standards and Technology, "Artificial intelligence risk management framework (AI RMF 1.0)," NIST, NIST AI 100-1, Jan. 2023. doi: 10.6028/NIST.AI.100-1.

[10] National Institute of Standards and Technology, "Artificial intelligence risk management framework: Generative artificial intelligence profile," NIST, NIST AI 600-1, Jul. 2024. doi: 10.6028/NIST.AI.600-1.

[11] European Parliament and Council, "Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act)." Jun. 2024. Available: https://eur-lex.europa.eu/eli/reg/2024/1689/oj

[12] Board of Governors of the Federal Reserve System and Office of the Comptroller of the Currency, "Supervisory guidance on model risk management (SR 11-7 / OCC bulletin 2011-12)," Federal Reserve, Apr. 2011. Available: https://www.federalreserve.gov/supervisionreg/srletters/sr1107.htm

[13] Prudential Regulation Authority, "Supervisory statement SS1/23: Model risk management principles for banks," Bank of England, May 2023. Available: https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss

[14] J. C. Crisanto, C. B. Leuterio, J. Prenio, and J. Yong, "Regulating AI in the financial sector: Recent developments and main challenges," Bank for International Settlements, Financial Stability Institute, FSI Insights No. 63, Dec. 2024.

[15] Financial Stability Board, "The financial stability implications of artificial intelligence," FSB, Nov. 2024.

[16] A. Chan *et al.*, "Visibility into AI agents," in *Proceedings of the 2024 ACM conference on fairness, accountability, and transparency (FAccT)*, 2024. doi: 10.1145/3630106.3658948.

[17] Y. Shavit *et al.*, "Practices for governing agentic AI systems." OpenAI white paper, Dec. 2023.

[18] ISO/IEC, "ISO/IEC 23894:2023 information technology — artificial intelligence — guidance on risk management." International Organization for Standardization, 2023.

[19] ISO/IEC, "ISO/IEC 22989:2022 information technology — artificial intelligence — artificial intelligence concepts and terminology." International Organization for Standardization, 2022.

[20] Hong Kong Monetary Authority, "Consumer protection in respect of use of generative artificial intelligence," HKMA, Aug. 2024.

[21] Veritas Consortium, "Veritas document 3A: FEAT fairness principles assessment methodology," Monetary Authority of Singapore, 2022. Available: https://www.mas.gov.sg/-/media/mas-media-library/news/media-releases/2022/veritas-document-3a---feat-fairness-principles-assessment-methodology.pdf

[22] Veritas Consortium, "Veritas document 3C: FEAT transparency principles assessment methodology," Monetary Authority of Singapore, 2022. Available: https://www.mas.gov.sg/-/media/mas-media-library/news/media-releases/2022/veritas-document-3c---feat-transparency-principles-assessment-methodology.pdf

[23] A. Chan *et al.*, "Harms from increasingly agentic algorithmic systems," in *Proceedings of the 2023 ACM conference on fairness, accountability, and transparency (FAccT)*, 2023. doi: 10.1145/3593013.3594033.

[24] S. Kapoor, B. Stroebl, Z. S. Siegel, N. Nadgir, and A. Narayanan, "AI agents that matter." 2024. Available: https://arxiv.org/abs/2407.01502

[25] Y. Ruan *et al.*, "Identifying the risks of LM agents with an LM-emulated sandbox," in *International conference on learning representations (ICLR)*, 2024.

[26] F. Perez and I. Ribeiro, "Ignore previous prompt: Attack techniques for language models." 2022. Available: https://arxiv.org/abs/2211.09527

[27] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, "Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection," in *Proceedings of the 16th ACM workshop on artificial intelligence and security (AISec)*, 2023. doi: 10.1145/3605764.3623985.

[28] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr, "AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents," in *Advances in neural information processing systems (NeurIPS) datasets and benchmarks*, 2024.

[29] Q. Zhan, Z. Liang, Z. Ying, and D. Kang, "InjecAgent: Benchmarking indirect prompt injections in tool-integrated large language model agents," in *Findings of the association for computational linguistics: ACL 2024*, 2024.

[30] A. Wei, N. Haghtalab, and J. Steinhardt, "Jailbroken: How does LLM safety training fail?" in *Advances in neural information processing systems (NeurIPS)*, 2023.

[31] A. Zou, Z. Wang, N. Carlini, M. Nasr, J. Z. Kolter, and M. Fredrikson, "Universal and transferable adversarial attacks on aligned language models." 2023. Available: https://arxiv.org/abs/2307.15043

[32] P. Chao, A. Robey, E. Dobriban, H. Hassani, G. J. Pappas, and E. Wong, "Jailbreaking black box large language models in twenty queries." 2023. Available: https://arxiv.org/abs/2310.08419

[33] M. Mazeika *et al.*, "HarmBench: A standardized evaluation framework for automated red teaming and robust refusal," in *International conference on machine learning (ICML)*, 2024.

[34] H. Inan *et al.*, "Llama guard: LLM-based input-output safeguard for human-AI conversations." 2023. Available: https://arxiv.org/abs/2312.06674

[35] T. Rebedea, R. Dinu, M. Sreedhar, C. Parisien, and J. Cohen, "NeMo guardrails: A toolkit for controllable and safe LLM applications with programmable rails," in *Proceedings of EMNLP 2023: System demonstrations*, 2023.

[36] L. Derczynski, E. Galinkin, J. Martin, S. Majumdar, and N. Inie, "Garak: A framework for security probing large language models." 2024. Available: https://arxiv.org/abs/2406.11036

[37] OWASP Foundation, "OWASP top 10 for large language model applications (2025)." 2025. Available: https://genai.owasp.org/llm-top-10/

[38] MITRE, "MITRE ATLAS: Adversarial threat landscape for artificial-intelligence systems." 2024. Available: https://atlas.mitre.org/

[39] P. Liang *et al.*, "Holistic evaluation of language models." 2022. Available: https://arxiv.org/abs/2211.09110

[40] L. Zheng *et al.*, "Judging LLM-as-a-judge with MT-bench and chatbot arena," in *Advances in neural information processing systems (NeurIPS) datasets and benchmarks*, 2023.

[41] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, "RAGAS: Automated evaluation of retrieval augmented generation," in *Proceedings of EACL 2024: System demonstrations*, 2024.

[42] S. Min *et al.*, "FActScore: Fine-grained atomic evaluation of factual precision in long form text generation," in *Proceedings of EMNLP 2023*, 2023.

[43] Z. Ji *et al.*, "Survey of hallucination in natural language generation," *ACM Computing Surveys*, vol. 55, no. 12, 2023, doi: 10.1145/3571730.

[44] UK AI Security Institute, "Inspect: A framework for large language model evaluations." 2024. Available: https://inspect.aisi.org.uk/

[45] M. Mitchell *et al.*, "Model cards for model reporting," in *Proceedings of the conference on fairness, accountability, and transparency (FAT*)*, 2019. doi: 10.1145/3287560.3287596.

[46] T. Gebru *et al.*, "Datasheets for datasets," *Communications of the ACM*, vol. 64, no. 12, 2021, doi: 10.1145/3458723.

[47] I. D. Raji *et al.*, "Closing the AI accountability gap: Defining an end-to-end framework for internal algorithmic auditing," in *Proceedings of the 2020 conference on fairness, accountability, and transparency (FAT*)*, 2020. doi: 10.1145/3351095.3372873.

[48] L. Weidinger *et al.*, "Taxonomy of risks posed by language models," in *Proceedings of the 2022 ACM conference on fairness, accountability, and transparency (FAccT)*, 2022. doi: 10.1145/3531146.3533088.

[49] M. Hardt, E. Price, and N. Srebro, "Equality of opportunity in supervised learning," in *Advances in neural information processing systems (NeurIPS)*, 2016.

[50] S. Barocas, M. Hardt, and A. Narayanan, *Fairness and machine learning: Limitations and opportunities*. MIT Press, 2023. Available: https://fairmlbook.org

[51] R. Bommasani *et al.*, "On the opportunities and risks of foundation models." 2021. Available: https://arxiv.org/abs/2108.07258